

Teoria 3 Parte 2 - PGP

PGP (Pretty Good Privacy)

- PGP (Pretty Good Privacy) es un conjunto de programas creados por Phil Zimmermann para proteger la información. Es un criptosistema híbrido que utiliza criptografía de clave pública o asimétrica, criptografía simétrica y funciones de hash.
- Al convertirse en uno de los mecanismos más populares para utilizar criptografía, la IETF tomó como base su diseño para crear el estándar OpenPGP.
- Además de proteger los datos en tránsito también permite proteger los datos almacenados en discos, copias de seguridad, etc.

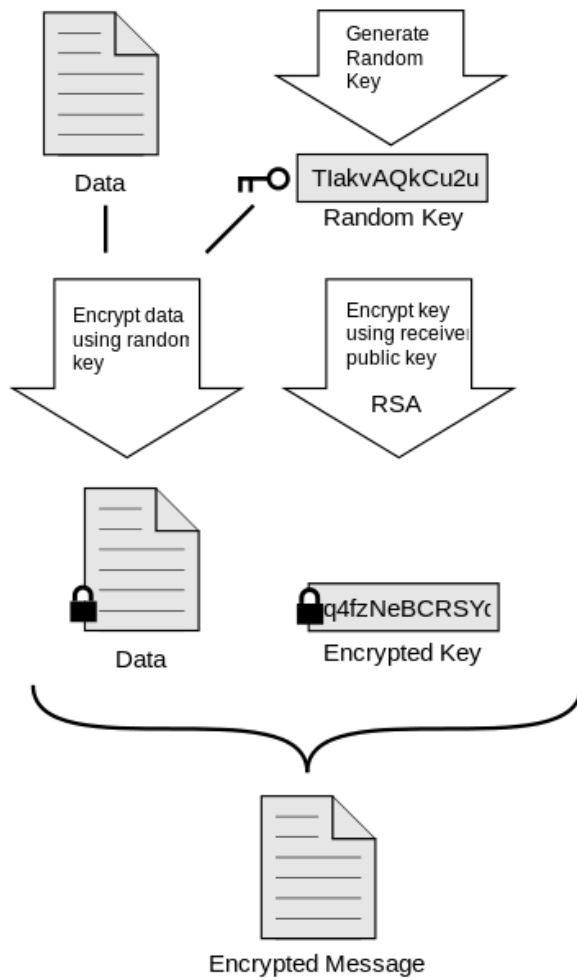
PGP vs OPENPGP vs GNUPG

- PGP: Actualmente propiedad de Symantec.
- OpenPGP: Estándar aprobado por el IETF (RFC 4880) que describe cualquier mecanismo de cifrado que use procesos interoperables con PGP
- GnuPG: Solución que sigue los estándares de OpenPGP desarrollada por la Free Software Foundation

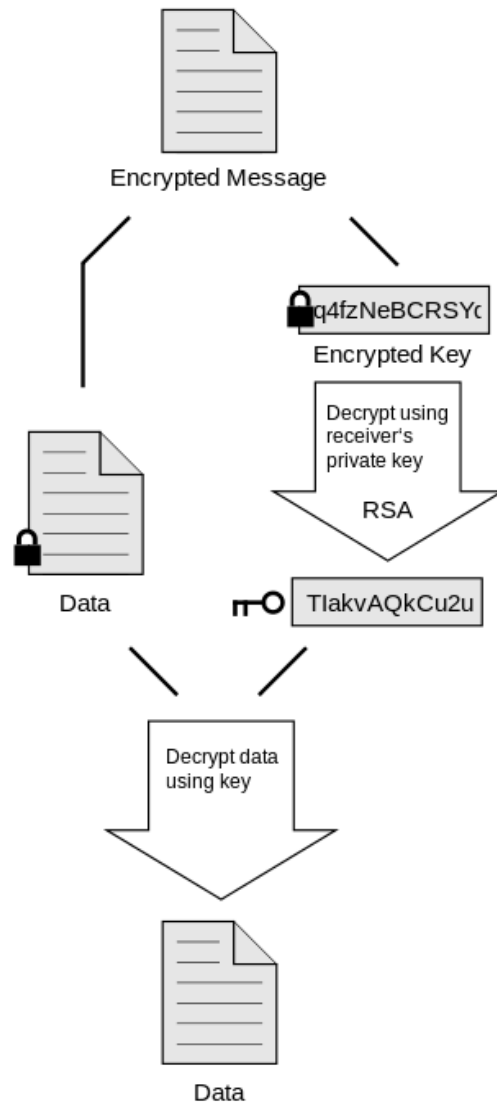
PGP - Claves

- En PGP, cada usuario genera un par de claves pública/privada.
- La clave pública es la que se puede compartir
- La clave privada nunca debe ser compartida
- Cada clave descifra un mensaje que fue encriptado con la otra.

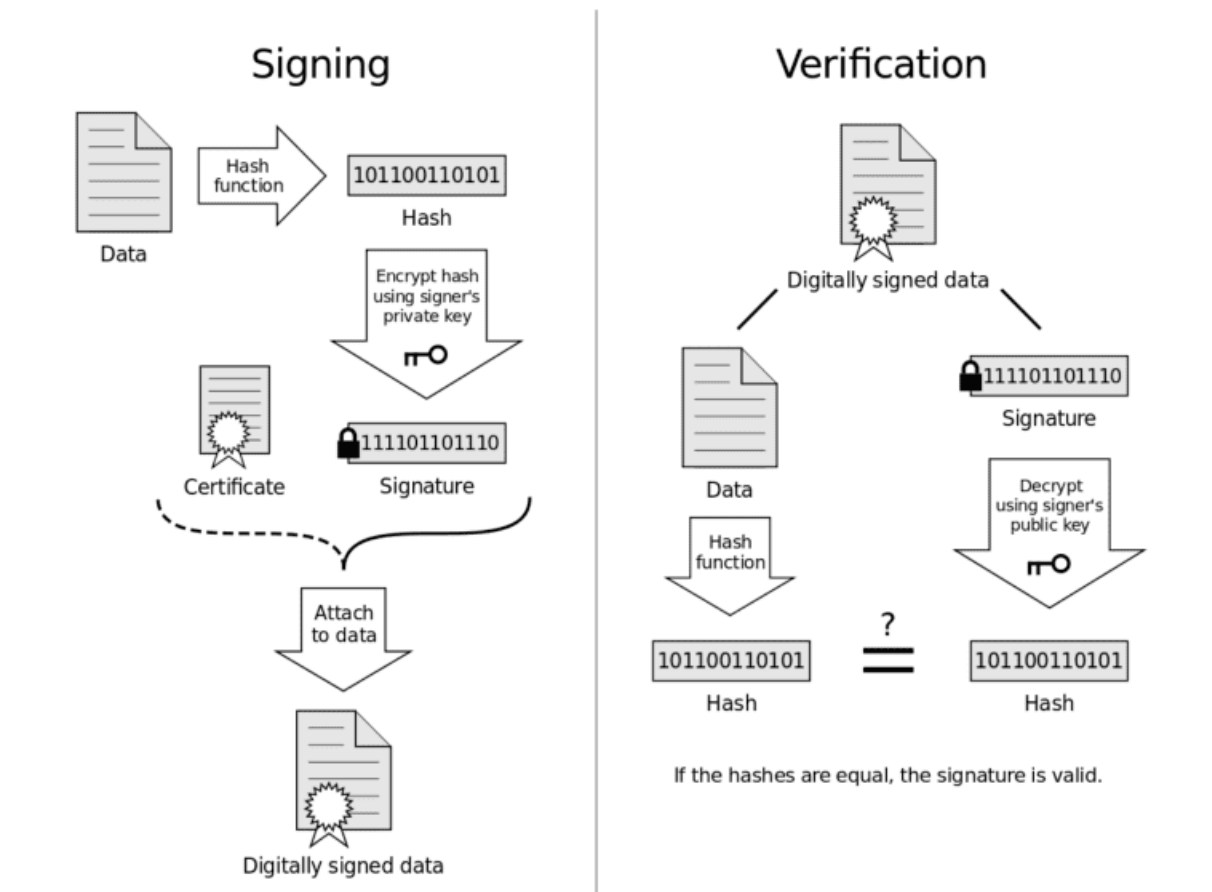
Encrypt



Decrypt



PGP - Firma



PGP - Fingerprint

- Las claves PGP tienen un fingerprint asociado, que básicamente es una versión corta.
- Las «huellas digitales» sirven para confirmar la identidad de la persona.

PGP - Certificado de renovación

- Una vez generado el par de claves, es recomendado generar un certificado de revocación que podrá ser utilizado en caso que la clave privada haya sido filtrada.
- Ante la presunción del leak de la clave, se debe subir el certificado de revocación a los servidores de claves para informar que la clave no es más válida.
- Almacenar de forma segura este certificado es tan importante como el resguardo de la clave privada.

PGP - Servidores de claves

- Los servidores de claves son repositorios utilizados para compartir las claves públicas.
- Es importante remarcar que cualquiera puede generar y distribuir claves para cualquier nombre y dirección de correo.
- El servidor más conocido es el que mantiene el MIT (<https://pgp.mit.edu/>), pero todos se encuentran sincronizados.

PGP - Cifrado vs Firma

- Cuando se encripta un mensaje o un archivo, se aumenta el nivel de confidencialidad.
- Cuando se firma, se aumenta el nivel de integridad y autenticidad.
- Un mensaje puede ser cifrado y/o firmado.

PGP - Red de confianza

Una red de confianza es un concepto utilizado para establecer qué tan confiable es un par de claves que se genera en un esquema descentralizado.

PGP - Anillos de claves

- Anillo de claves públicas: Archivo en el que se guardan las claves públicas del usuario propietario y las claves públicas importadas
- Anillo de claves privadas: archivos en el que se guardan la/s clave/s privada/s del usuario propietario
- Si podemos confirmar la persona que utiliza una clave en particular, podemos firmar dicha clave con nuestra clave privada. Esto permitirá:
 - Certificar que dicha clave efectivamente pertenece a esa persona
 - Evitar la manipulación de nuestro anillo de claves por parte de un tercero
 - Al igual que las claves públicas, las firmas realizadas a una clave también se pueden subir.
 - Las reuniones donde se validan, intercambian y se firman claves se las conoce como PGP Parties.

PGP - Esquema de confianza

- La confianza es algo subjetivo
- Yo puedo confiar en la clave de una persona, pero no confiar en las claves en las que esa persona confía
- Se pueden establecer relaciones de confianza indirectas.

¿Como usar PGP?

- Generar par de Claves (Pública/Privada)
- Configurar Cliente de Correo por ejemplo Thunderbird.
- Resguardar la clave privada adecuadamente
- Intercambiar con el circulo de confianza la clave pública. PGPpartys.
- Incorporar claves públicas de terceros a tu llavero → Fingerprint

PGP - Ventajas

- Su fuerte radica en la facilidad para generar claves y gestionarlas, con un amplio campo de aplicación:
- Comunicación entre individuos en correo electrónico.
- Cifrado de archivos y mensajes.
- Existen versiones libres y comerciales que implementan PGP, para manejo de claves y operaciones de criptografía, las cuales están disponibles para gran variedad de plataformas.
- Basado en algoritmos extensamente revisados y considerados ampliamente seguros (RSA, DSS y Diffie-Hellman; CAST-128, IDEA y 3DES; SHA-1)
- El software y la documentación están disponibles en Internet
- Existen versiones comerciales y libres que implementan los servidores de clave PGP
- No fue desarrollado por ningún gobierno ni organización de creación de estándares, lo cual lo hace atractivo.

PGP - Desventajas

- La gestión de claves en PGP se basa en la confianza mutua: !Los amigos de tus amigos son mis amigos!

- En un sistema abierto en Internet como el comercio electrónico, esta situación y otras más que pueden darse en este sistema de gestión de claves de confianza mutua, resulta inaceptable.

Relación entre PGP y Triangulo CIA

- ¿Qué protejo si firmo un mail con mi clave privada? → ASEGURO INTEGRIDAD
El mensaje no se puede alterar ya que la firma no coincide y nadie lo puede escribir originalmente, excepto el dueño de la privada
- ¿Qué protejo si encripto un mensaje con la clave pública del destinatario? → ASEGURO CONFIDENCIALIDAD
Nadie puede leer el mensaje, excepto el dueño de la clave privada que se corresponde con la pública utilizada
- Si se hacen las 2 → Aseguro integridad y confidencialidad
- ¿Que se sucede si el destinatario pierde su clave privada? → Se pierde disponibilidad
- ¿Que ocurre si en vez de perderse alguien roba la clave privada del emisor o destinatario?
Con la del emisor → Se pierde integridad
Con la del destinatario → Se pierde confidenciabilidad